

OpenSSL 제외 RFC 5246/8446 관련 CVE 발생 원인 정리

이 문서는 2020-2026년 CVE 중 현재 RFC 5246/RFC 8446 모델 범위와 관련된 항목에서 OpenSSL을 제외한 34개 CVE를 정리한다.

집계 기준 파일은 다음과 같다.

- maude/docs/cve-analysis/collected-cves.json
- maude/docs/cve-analysis/classification-table.md
- maude/docs/cve-analysis/not-yet-implemented.md
- maude/docs/cve-analysis/summary.md
- maude/scenario/cve/ 아래 관련 CVE 시나리오 파일

아래의 CVE 설명과 patch/fix 정보는 로컬에 수집된 vendor advisory 텍스트를 기준으로 했다. 원 출처는 각 라이브러리의 보안 공지 페이지다.

- wolfSSL: <https://www.wolfssl.com/docs/security-vulnerabilities/>
- GnuTLS: <https://www.gnutls.org/security-new.html>
- Mbed TLS: <https://mbed-tls.readthedocs.io/en/latest/security-advisories/>

집계 요약

기준	개수
2020-2026 RFC 5246/8446 관련 CVE, OpenSSL 제외	34
현재 CVE 분석 상태에서 구현됨 또는 프로토콜 트리거 모델링됨	19
현재 모델 범위 밖 / 미구현	15

라이브러리별 집계는 다음과 같다.

Library	전체	구현됨	모델 범위 밖 / 미구현
wolfSSL	25	15	10
GnuTLS	7	2	5
Mbed TLS	2	2	0
OpenSSL	0	0	0

모델 범위 밖 / 미구현 15개는 다음과 같다.

CVE-2020-12457, CVE-2020-24659, CVE-2021-20231, CVE-2021-20232, CVE-2022-39173, CVE-2022-42905, CVE-2023-0361, CVE-2023-6935, CVE-2023-6936, CVE-2023-6937, CVE-2024-0901, CVE-2025-11932, CVE-2026-5260, CVE-2026-5446, CVE-2026-5778.

모델 범위 밖 사유 분류

사유	개수	CVE
구체 parser, heap, object lifetime, resource, error-path 동작 필요	8	CVE-2020-12457, CVE-2020-24659, CVE-2021-20231, CVE-2021-20232, CVE-2022-39173, CVE-2022-42905, CVE-2023-6936, CVE-2024-0901
timing, oracle, repeated-query, constant-time 관찰 필요	3	CVE-2023-0361, CVE-2023-6935, CVE-2025-11932
구체 crypto, record protection, AEAD, nonce, RSA, sniffer byte semantics 필요	3	CVE-2026-5260, CVE-2026-5446, CVE-2026-5778
현재 symbolic handshake 모델에 없는 record encryption-state/key-boundary 의미 필요	1	CVE-2023-6937

CVE별 발생 원인

CVE	Library	CVE 분석 상태	취약 입력값 / 발생 원인	Library website description 근거	Patch/fix 정보 근거	모델 범위 판정
CVE-2020-12457	wolfSSL	모델 범위 밖 / 미구현	입력은 TLS 1.3 handshake 중 또는 직후 ChangeCipherSpec record를 반복 전송하는 것이다. 구체적으로 ContentType = change_cipher_spec , payload 0x01인 CCS를 정상 handshake 진행보다 훨씬 많이 보내 서버가 매번 처리하게 만든다.	wolfSSL advisory는 TLS 1.3 서버에 반복 CCS를 보내는 DoS를 설명한다.	advisory는 TLS 1.3 CCS 수신 횟수를 제한하는 최신 wolfSSL 릴리스를 업데이트하라고 권고한다.	protocol-action은 있지만 영향은 resource/cve와 구체 처리
CVE-2020-24613	wolfSSL	구현 됨	입력은 non-PSK TLS 1.3 server flight에서 Certificate 와 CertificateVerify 를 모두 생략하고 EncryptedExtensions 다음에 바로 Finished 를 보내는 것이다. 모델에서는	wolfSSL advisory는 TLS 1.3 client-side MITM/server	local status는 TLS 1.3 server-authentication omission scenario가 구현되었다고 기록한다.	RFC 8446 : authenticating 가능하다.

CVE	Library	CVE 분석 상태	취약 입력값 / 발생 원인	Library website description 근거	Patch/fix 정보 근거	모델 범위 판
			<code>buildServerCertificateV3</code> 와 <code>buildServerCertificateVerifyV3</code> 를 <code>skip()</code> 한다.	impersonation 문제를 설명한다.		crash나 구형 델 밖이다.
CVE-2020-24659	GnuTLS	모델 범위 밖 / 미구현	입력은 TLS 1.3 client에게 예상되지 않은 시점의 <code>AlertDescription = no_renegotiation</code> alert를 보내고, 이어서 invalid second handshake message를 보내는 순서다. 이 조합이 handshake failure 뒤 error cleanup 경로를 자극한다.	GnuTLS advisory는 oss-fuzz, issue #1071, handshake failure 뒤 <code>gnutls_deinit</code> 경로의 null pointer dereference를 언급한다.	advisory는 GnuTLS 3.6.15 이상으로 업그레이드하라고 권고한다.	TLS 흐름은 ; parser/erro nullability와 lifetime ser 하다.
CVE-2021-3336	wolfSSL	구현 됨	입력은 server <code>Certificate</code> 에는 RSA end-entity certificate를 넣고, 이어지는 TLS 1.3 <code>CertificateVerify.signature_algorithm</code> 은 <code>{ecdsa, sha256}</code> 으로 보내는 것이다. 두 algorithm은 client가 모두 offer했지만 <code>CertificateVerify</code> 에 대응되는 ECDSA public key가 없다.	wolfSSL advisory는 TLS 1.3 client-side MITM 문제와 PR #3676을 언급한다.	local scenario status는 <code>CertificateVerify/certificate-key mismatch rejection</code> 을 모델링한다.	RFC 8446 Certificate\certificate-사는 모델링 ;
CVE-2021-20231	GnuTLS	모델 범위 밖 / 미구현	입력은 매우 큰 TLS 1.3 <code>ClientHello</code> 다. 특히 HRR/resumption 맥락에서 큰 FFDHE parameter를 동반한 <code>key_share</code> 또는 <code>pre_shared_key</code> extension을 넣어 내부 buffer <code>realloc()</code> 이 발생하도록 만든다.	GnuTLS advisory는 TLS 1.3 large <code>ClientHello</code> , HRR/resumption, large FFDHE parameter, issue #1151을 언급한다.	advisory는 GnuTLS 3.7.1 이상으로 업그레이드하라고 권고한다.	byte-level ; allocation, pointer lifet semantics?
CVE-2021-20232	GnuTLS	모델 범위 밖 / 미구현	입력은 CVE-2021-20231과 같은 형태의 large TLS 1.3 <code>ClientHello</code> 다. <code>key_share</code> 또는 <code>pre_shared_key</code> extension 크기를 키워 extension parsing 중 reallocation 이후 오래된 pointer가 다시 쓰이도록 만든다.	GnuTLS advisory는 <code>key_share</code> 또는 <code>pre_shared_key</code> extension 처리와 issue #1151을 다시 언급한다.	advisory는 GnuTLS 3.7.1 이상으로 업그레이드하라고 권고한다.	RFC 8446 이 는 관련 있지; heap/objec 다.
CVE-2021-44718	wolfSSL	구현 됨	입력은 TLS 1.2 이하 client가 server flight를 기다리는 상태에서 반대 방향 Hello handshake message를 주입하는 것이다. 즉 MITM이 연결 방향에 맞지 않는 Hello packet을 client에게 전달한다.	wolfSSL advisory는 TLS 1.2 이하에서 incorrect-side hello packet 처리를 설명한다.	local status는 bounded TLS 1.2 wrong-side Hello rejection scenario를 구현했다고 기록한다.	예상 밖 hanc message 빙 능하지만 cor loop/DoS 호 다.
CVE-2022-25638	wolfSSL	구현 됨	입력은 TLS 1.3 server가 RSA certificate를 보낸 뒤 <code>CertificateVerify.signature_algorithm</code> 만 <code>{ecdsa, sha256}</code> 으로 바꾸어 보내는 것이다. 실제 취약 조건은 <code>CertificateVerify</code> algorithm과 certificate key type의 불일치다.	wolfSSL advisory는 <code>sig_algo</code> 차이로 TLS 1.3 client의 server certificate check가 우회될 수 있다고 설명한다.	local scenario는 <code>CertificateVerify signature-algorithm/certificate-key mismatch</code> 를 모델링한다.	RFC 8446 Certificate\algorithm/k consistency
CVE-2022-25640	wolfSSL	구현 됨	입력은 server가 TLS 1.3 <code>CertificateRequest</code> 를 보낸 뒤 client가 <code>Certificate</code> 는 보내지만 <code>CertificateVerify</code> 를 생략하고 바로 <code>Finished</code> 를 보내는 것이다. 모델에서는 client <code>CertificateVerify</code> build action을 <code>skip()</code> 한다.	wolfSSL advisory는 mutual authentication required server를 client <code>CertificateVerify</code> 없이 우회할 수 있다고 설명한다.	local scenario는 client <code>CertificateVerify</code> omission을 모델링한다.	core TLS 1. authenticat 델링한다.
CVE-2022-39173	wolfSSL	모델 범위 밖 / 미구현으로 집계	입력은 TLS 1.3 session-ticket resumption에서 reconnecting <code>ClientHello.cipher_suites</code> 에 같은 cipher suite를 중복으로 넣고, HRR 뒤 second <code>ClientHello</code> 에도 같은 duplicate cipher suite list를 다시 넣는 것이다. 이 malformed resumption path가 내부 <code>RefineSuites</code> buffer crash/overflow를 유발한다.	wolfSSL advisory는 --enable-session-ticket TLS 1.3 server가 malformed second <code>ClientHello</code> 로 crash할 수 있다고 설명한다.	cve-2022-39173.maude는 duplicate cipher-suite HRR/resumption trigger를 모델링하지만, collected-cves.json과 classification-table.md는 아직 not-yet-implemented로 분류한다.	protocol tri 로 표현 가능; CVE impac; parser/buff crash sema 다. 가장 중요 item이다.
CVE-2022-42905	wolfSSL	모델 범위 밖 / 미구현	입력은 WOLFSSL_CALLBACKS가 켜진 build에서 TLS 1.3 client connection 처리 경로로 들어오는 malformed TLS 1.3 handshake message다. 핵심은 callback/debug 경로가 message buffer 끝을 넘어 5 byte를 읽도록 하는 짤거나 잘못된 구성된 입력이다.	wolfSSL advisory는 explicit WOLFSSL_CALLBACKS build와 TLS 1.3 client handling으로 범위를 제한한다.	advisory는 WOLFSSL_CALLBACKS 비활 성화 또는 wolfSSL 업데이트를 권고한다.	build-optio callback pa bounds, pa semantics?
CVE-2023-0361	GnuTLS	모델 범위 밖 /	입력은 TLS 1.2 RSA key exchange에서 <code>ClientKeyExchange.encrypted_pre_master_secret</code> 에 PKCS#1 v1.5 padding이 잘못된 RSA ciphertext를 반복 주입하는 것이	GnuTLS advisory는 only TLS ciphertext processing affected라	advisory는 GnuTLS 3.8.0 이상으로 업그레이드하라고 권고한다.	attacker-vi; timing/orac query, cost 필요하다.

CVE	Library	CVE 분석 상태	취약 입력값 / 발생 원인	Library website description 근거	Patch/fix 정보 근거	모델 범위 판
		미구현	다. 정상 padding ciphertext와 malformed ciphertext의 응답 시간을 비교한다.	고 설명하고 issue #1050 을 언급한다.		
CVE-2023-3724	wolfSSL	구현됨	입력은 TLS 1.3 <code>ServerHello</code> 에서 PSK identity 선택도 하지 않고 <code>key_share</code> extension도 제거한 메시지다. 모델에서는 malicious server가 <code>remove(#key-shares)</code> 로 <code>ServerHello</code> <code>key_share</code> 를 빼며, non-PSK 설정이라 shared secret이 <code>noNonce</code> 로 흐른다.	wolfSSL advisory는 missing PSK/key_share가 weak session master secret derivation을 만든다고 설명한다.	advisory는 PR #6412 를 언급하고 scenario comments는 <code>ServerHello</code> <code>key_share</code> sanity check를 설명한다.	RFC 8446 : <code>key_share</code> r 모델링한다.
CVE-2023-6935	wolfSSL	모델 범위 밖 / 미구현	입력은 TLS 1.2 이하 static RSA cipher suite에서 여러 형태의 malformed RSA <code>ClientKeyExchange</code> ciphertext를 대량으로 보내는 것이다. 공격자는 각 probe의 timing 차이를 모아 Marvin-style oracle을 만든다.	wolfSSL advisory는 RSA timing, TLS 1.2 이하 static RSA cipher suite, TLS 1.3에서 static RSA 제거를 설명한다.	advisory는 PR #6955 , static RSA 비활성화, wolfSSL 업데이트를 언급한다.	timing orac 필요하므로 s handshake
CVE-2023-6936	wolfSSL	모델 범위 밖 / 미구현	입력은 <code>WOLFSSL_CALLBACKS</code> 가 켜진 TLS 1.3 server에게 보내는 malformed <code>ClientHello</code> 다. message length나 extension layout 이 callback parser의 bounds assumptions를 깨뜨려 heap/OOB read를 유발한다.	wolfSSL advisory는 TLS 1.3 server connection과 <code>WOLFSSL_CALLBACKS</code> 에서 heap/OOB read를 설명한다.	advisory는 PR #6949 와 wolfSSL 5.6.6 업데이트를 언급한다.	callback-sp concrete p; buffer bour
CVE-2023-6937	wolfSSL	모델 범위 밖 / 미구현	입력은 하나의 TLS 1.3 record 안에 key boundary 양쪽의 handshake message를 섞는 것이다. 대표적으로 unencrypted record 하나에 <code>ServerHello</code> 와 그 뒤 encrypted state에서 처리되어야 할 나머지 server flight를 함께 넣는다.	wolfSSL advisory는 record 내 message key boundary 미검사를 설명하고 TLS 1.3 encryption transition 을 언급한다.	advisory는 PR #7029 를 언급한다.	record-pro key-bound; encryption- semantics?
CVE-2024-0901	wolfSSL	모델 범위 밖 / 미구현	입력은 TLS 1.3 server가 받는 malicious <code>ClientHello</code> 로, padding/length/bounds 관련 extension 또는 field를 비정상 크기로 구성해 parser가 OOB read와 DoS 경로에 들어가게 하는 것이다.	wolfSSL advisory는 TLS 1.3 server-side DoS/OOB read를 설명한다.	advisory는 PR #7099 를 언급한다.	concrete padding/bc 와 memory- semantics?
CVE-2024-5814	wolfSSL	구현됨	입력은 client가 TLS 1.2 <code>ClientHello.cipher_suites</code> 에 <code>TLS-ECDSA-WITH-AES-128-GCM-SHA256</code> 만 넣었는데, malicious server가 <code>ServerHello.cipher_suite = TLS-ECDSA-WITH-AES-256-GCM-SHA384</code> 로 응답하는 것이다.	wolfSSL advisory는 malicious TLS 1.2 server가 unagreed cipher suite를 강제할 수 있다고 설명한다.	advisory는 PR #7619 를 언급한다.	TLS 1.2 Ser cipher-suite 을 모델링한다
CVE-2025-6395	GnuTLS	구현됨	입력은 TLS 1.3 첫 <code>ClientHello</code> 에는 PSK extension을 포함하고, server가 HRR을 보낸 뒤 두 번째 <code>ClientHello</code> 에서는 그 PSK extension을 제거하는 것이다.	GnuTLS advisory는 HRR plus second ClientHello PSK omission과 issue #1718 을 설명한다.	advisory는 GnuTLS 3.8.10 이상으로 업그레이드하라고 권고한다.	RFC 8446 : ClientHello 모델링하며 n dereferenc; 모델 밖이다.
CVE-2025-11932	wolfSSL	모델 범위 밖 / 미구현	입력은 TLS 1.3 PSK resumption <code>ClientHello.pre_shared_key.binders</code> 에 여러 binder guess 값을 넣어 반복 전송하는 것이다. 취약점은 binder 비교가 constant-time이 아니어서 prefix 일치 정도가 timing으로 드러날 수 있다는 점이다.	wolfSSL advisory는 PSK binder verification timing side-channel을 설명한다.	local advisory text에는 특정 PR이 없다.	timing/cons observatio 필요하다.
CVE-2025-11933	wolfSSL	구현됨	입력은 TLS 1.3 <code>ClientHello.extensions</code> 에 CKS extension을 중복으로 넣는 것이다. 모델에서는 기본 CKS 하나에 <code>add(#cks, mv[true]), add(#cks, mv[false])</code> 를 추가해 총 세 개의 CKS extension이 되게 한다.	wolfSSL advisory는 TLS 1.3 ClientHello duplicate CKS extension parsing을 설명한다.	scenario comments는 PR #9132 의 duplicate <code>TLSX_CKS</code> detection을 언급한다.	duplicate e trigger는 모 memory lea impact는 모
CVE-2025-11934	wolfSSL	구현됨	입력은 client <code>signature_algorithms = {ecdsa,sha512}</code> 만 offer했는데 server <code>CertificateVerify.signature_algorithm = {ecdsa,sha256}</code> 으로 보내는 것이다. 즉 signature type은 ECDSA로 같지만 hash가 SHA-512에서 SHA-256으로 downgrade된다.	wolfSSL advisory는 ECDSA P521-to-P256 signature downgrade 를 설명한다.	scenario comments는 PR #9113 의 peer <code>signature_algorithms</code> membership check를 언급한다.	RFC 8446 : algorithm s Certificate\ 모델링한다.

CVE	Library	CVE 분석 상태	취약 입력값 / 발생 원인	Library website description 근거	Patch/fix 정보 근거	모델 범위 판
CVE-2025-11935	wolfSSL	구현 됨	입력은 TLS 1.3 PSK reconnect에서 client가 <code>psk_key_exchange_modes = psk_dhe_ke</code> 와 <code>key_share</code> 를 보냈는데, server가 PSK는 선택하면서 <code>ServerHello.key_share</code> 를 생략하는 것이다. 모델에서는 <code>remove(#key-shares)</code> 로 PSK-DHE를 PSK-only로 바꾼다.	wolfSSL advisory는 TLS 1.3 handshake에서 PSK with PFS가 PSK without PFS로 downgrade된다고 설명한다.	scenario comments는 PR #9112 의 <code>key_share-derived secret tracking</code> 을 언급한다.	RFC 8446 I exchange n key_share c 모델링한다.
CVE-2025-11936	wolfSSL	구현 됨	입력은 TLS 1.3 <code>ClientHello.key_share</code> 에 같은 group의 <code>KeyShareEntry</code> 를 두 개 넣는 것이다. 모델의 구체값은 <code>{secp256r1, ecdh(secp256r1, nonce(...,0))}</code> 와 <code>{secp256r1, ecdh(secp256r1, nonce(...,2))}</code> 의 중복 group list다.	wolfSSL advisory는 malicious TLS 1.3 <code>ClientHello</code> 의 multiple same-group <code>KeyShareEntry</code> 를 설명한다.	scenario comments는 PR #9117 의 duplicate group rejection을 언급한다.	duplicate K trigger는 모 memory lea impact는 모
CVE-2025-12889	wolfSSL	구현 됨	입력은 TLS 1.2 server <code>CertificateRequest.supported_signature_algorithms = {ecdsa,sha256}</code> 인데 client <code>CertificateVerify</code> 의 declared algorithm을 <code>{dsa,sha}</code> 로 바꾸는 것이다. 여기서 <code>sha</code> 는 SHA-1이며, 실제 key/signature는 ECDSA라 algorithm list와 key type 양쪽을 어긴다.	wolfSSL advisory는 TLS 1.2 connection에서 <code>CertificateRequest</code> 의 digest 대신 임의 digest를 사용할 수 있다고 설명한다.	local scenario는 <code>CertificateVerify digest downgrade</code> 를 모델링한다.	RFC 5246 Certificate\ algorithm/c compatibili
CVE-2026-1005	wolfSSL	구현 됨	입력은 TLS 1.2 AEAD cipher suite 협상 뒤 sniffer가 보는 encrypted record를 <code>ContentType = application_data, recordLen = minSize</code> 로 만드는 것이다. payload length가 explicit IV와 authentication tag 고정 길이보다 작아 length underflow trigger가 된다.	wolfSSL advisory는 <code>ssl_DecodePacket</code> , AEAD explicit-IV/tag length, malformed TLS Application Data record를 설명한다.	local scenario는 short AEAD record trigger를 모델링한다.	짧은 record 링하지만 cor heap overfl byte operat 다.
CVE-2026-1584	GnuTLS	구현 됨	입력은 TLS 1.3 ticket-based resumption <code>ClientHello</code> 에서 PSK identity는 정상 ticket으로 두되 <code>pre_shared_key.binders</code> 에는 길이와 형태는 맞지만 MAC 값이 틀린 binder를 넣는 것이다. 모델에서는 <code>setM(#psk-binders, mv[invalidBinders1584])</code> 를 사용한다.	GnuTLS advisory는 invalid PSK binder in <code>ClientHello</code> 와 issue #1790 을 설명한다.	advisory는 GnuTLS 3.8.12 이상 권고와 3.8.10 이하 비영향을 언급하며, local scenario comments는 fix commit을 언급한다.	invalid bind 모델링하고 p behavior는
CVE-2026-2645	wolfSSL	구현 됨	입력은 TLS 1.2 client-auth handshake에서 server가 <code>ClientKeyExchange</code> 를 기다리는 시점에 client가 handshake type을 <code>certificate_verify</code> 로 바꾸어 먼저 보내는 것이다. 모델에서는 <code>buildClientKeyExchangeV2</code> 메시지의 <code>#handshakeType</code> 을 <code>certificate_verify</code> 로 설정한다.	wolfSSL advisory는 wolfSSL 5.8.2 이하의 TLS 1.2 server state-machine logic flaw를 설명한다.	advisory는 5.8.4에서 감지하고 5.9.0에서 더 이른 handshake 단계에서 hardening했다고 설명한다.	TLS 1.2 har message o 링한다.
CVE-2026-3230	wolfSSL	구현 됨	입력은 첫 <code>ClientHello</code> 에 <code>key_share = secp256r1</code> 와 <code>supported_groups</code> 에 <code>secp521r1</code> 를 포함하고, server가 <code>HelloRetryRequest</code> 로 <code>secp521r1</code> 를 요청한 뒤 최종 <code>ServerHello</code> 에서 필수 <code>key_share</code> 를 제거하는 것이다. 모델에서는 <code>remove(#key-shares)</code> 로 post-HRR <code>ServerHello</code> 를 만든다.	wolfSSL advisory는 crafted <code>HelloRetryRequest</code> 이후 required <code>key_share</code> missing을 설명한다.	scenario comments는 PR #9754 의 <code>shSentKeyShare</code> 기반 검사를 언급한다.	RFC 8446 I HRR key_sl requiremen
CVE-2026-5260	GnuTLS	모델 범위 밖 / 미구현	입력은 PKCS#11-backed RSA private key를 쓰는 TLS server에게 RSA <code>ClientKeyExchange</code> 를 보내되, decrypted premaster secret 길이가 정상 48 bytes보다 극단적으로 짧게 나오도록 만든 ciphertext다.	GnuTLS advisory는 issue #1814 와 RSA key exchange의 short premaster secret을 언급한다.	advisory는 GnuTLS 3.8.13 이상으로 업그레이드하라고 권고한다.	RFC 5246 I ClientKeyE: 있지만 conc decrypt, pr secret leng token, heap semantics?
CVE-2026-5446	wolfSSL	모델 범위 밖 / 미구현	입력은 MagicCrypto/ <code>---enable-aria</code> build에서 TLS 1.2 ARIA-GCM cipher suite를 협상하고 여러 encrypted record를 보내는 것이다. 취약 경로는 record nonce construction이 서로 다른 record에 같은 GCM nonce를 재사용하는 경우다.	wolfSSL advisory는 ARIA support가 MagicCrypto와 <code>---enable-aria</code> 를 필요로 한다고 설명한다.	local advisory text에는 특정 PR이 없다.	concrete TI nonce cons ARIA-GCM semantics?
CVE-2026-5778	wolfSSL	모델 범위 밖 / 미구현	입력은 sniffer build에서 TLS 1.2 ChaCha20-Poly1305 record를 payload length가 AEAD MAC/tag size보다 짧게 만든 malformed <code>ApplicationData</code> record다. length 계산이 tag size subtraction에서 underflow되어 OOB read로 이어진다.	wolfSSL advisory는 malformed TLS 1.2 record, ChaCha20-Poly1305, sniffer build, length underflow를 설명한다.	local advisory text에는 특정 PR이 없다.	concrete A arithmetic, sniffer pars byte-level r semantics?
CVE-2026-25834	Mbed TLS	구현 됨	입력은 TLS 1.2 client가 <code>signature_algorithms = {ecdsa,sha512}</code> 만 advertise했는데, server가 <code>ServerKeyExchange.signature_algorithm = {ecdsa,sha256}</code> 으로 서명해 보내는 것이다. algorithm은	Mbed TLS advisory title은 Signature Algorithm Injection이며, local scenario	scenario comments는 Mbed TLS fix가 client-side check를 바꿔 unoffered algorithm을 reject한다고 설명한다.	RFC 5246 S signature_ε membershi

CVE	Library	CVE 분석 상태	취약 입력값 / 발생 원인	Library website description 근거	Patch/fix 정보 근거	모델 범위 판
			syntactically valid이고 implementation-supported지만 client가 offer하지 않았다.	comments는 client가 <code>{ecdsa,sha512}</code> 만 offer했는데 server가 <code>{ecdsa,sha256}</code> 을 쓰는 경우를 설명한다.		
CVE-2026-34873	Mbed TLS	구현 됨	입력은 TLS 1.3 PSK reconnect 중 server HRR을 받은 뒤 follow-up ClientHello가 더 이상 TLS 1.3을 협상하지 않도록 cross-version 상태를 만든 것이다. 모델은 HRR 처리 직후 server/client state를 TLS 1.2 resumption state로 바꾸고 <code>sessionState(..., ms(...))</code> 로 fabricated TLS 1.2 master_secret을 주입한다.	collected-cves.json에는 짧은 Mbed TLS 설명만 있지만 local scenario comments는 HRR-to-TLS-1.2 resumption state deviation을 설명한다.	scenario는 vulnerable behavior의 server/client cross-version object-state transition을 모델링한다.	mixed TLS 1.2 resumption deviation은 concrete ru limitation은 happy-flow다.

주의 사항

- OpenSSL은 의도적으로 제외했다. 이전 45개 집계에는 OpenSSL 11개가 포함되어 있었고, 이를 제거하면 34개가 된다.
- CVE-2022-39173은 maude/scenario/cve에 시나리오 파일이 있지만, 현재 CVE 분석 데이터는 이 항목을 아직 not-yet-implemented로 집계한다. 이유는 집계 대상 취약 영향이 concrete parser/buffer crash이기 때문이다. 따라서 이 문서도 count consistency를 위해 15개 모델 범위 밖 항목에 넣었다.
- 구현됨으로 표시된 항목 중에도 concrete crash, memory leak, heap overflow 효과가 남아 있는 경우가 있다. 이 경우 현재 모델은 protocol trigger 또는 rejection condition을 포착하고, concrete memory/resource impact는 포착하지 않는다.